

NetSec

Práctica de Seguridad en Redes — Topología FortiGate

Estudiante: Enmanuel Feliz Soto

Matrícula: 20251402

Materia: Seguridad en Redes — Sección 5 (Lunes)

Profesor: Jonathan Esteban Rondón Corniel

Institución: ITLA — Instituto Tecnológico de las Américas

Plataforma: FortiGate-VM64-KVM v7.6.7

1. Objetivo

Implementar una topología de red segura en FortiGate que cumpla, mediante configuración exclusiva por GUI, con los siguientes requisitos: acceso a Internet, segmentación de LAN de usuarios (/25) y LAN de servidores (/28), direccionamiento IP, DHCP, ruta por defecto, NAT, control de acceso entre segmentos (solo HTTP), bloqueo de redes sociales, bloqueo de llamadas de WhatsApp, bloqueo del dominio itla.edu.do, detección de escáneres de red (IPS) y protección WAF al servidor web.

2. Topología general

Interfaz	Nombre	Rol	Dirección IP	Máscara
port1	WAN	Salida a Internet	10.0.0.202	/24 (255.255.255.0)
port2	LAN-USERS	LAN de usuarios	14.2.10.1	/25 (255.255.255.128)
port3	LAN-SERVERS	LAN de servidores	14.2.20.1	/28 (255.255.255.240)

3. Configuración de interfaces y direccionamiento

3.1 Interfaces de red

Configuración de port1 (WAN), port2 (LAN-USERS) y port3 (LAN-SERVERS), cada una con su rol, dirección IP y accesos administrativos habilitados (PING, HTTPS, SSH).

Name	Type	Members	IP/Netmask	Administrative access
802.3ad Aggregate	802.3ad Aggregate			
fortilink	802.3ad Aggregate		Dedicated to FortiSwitch	PING Security Fabric Connection
Physical Interface	Physical Interface			
LAN-SERVERS (port3)	Physical Interface		14.2.20.1/255.255.255.240	PING HTTPS SSH
LAN-USERS (port2)	Physical Interface		14.2.10.1/255.255.255.128	PING HTTPS SSH Speed Test
port1	Physical Interface		10.0.0.202/255.255.255.0	PING HTTPS SSH HTTP
Tunnel Interface	Tunnel Interface			
NAT interface (naf.root)	Tunnel Interface		0.0.0.0/0.0.0.0	
WiFi SSID	WiFi SSID			
fortinet.mesh.root (default-mesh)	WiFi SSID		0.0.0.0/0.0.0.0	

Tabla de interfaces de red

3.2 DHCP en LAN de usuarios

- Estado: Enabled

- Rango de direcciones: 14.2.10.10 – 14.2.10.126
- Máscara: 255.255.255.128
- Gateway: Same as Interface IP (14.2.10.1)
- DNS: 1.1.1.1, 14.2.10.1, 8.8.8.8
- Lease time: 604800 segundos (7 días)

Edit Interface

Name: LAN-USERS (port2)
 Alias: LAN-USERS
 Type: Physical Interface
 VRF ID: 0
 Role: Undefined

Addressing mode: Manual IPAM DHCP PPPoE
 IP/Netmask: 14.2.10.1/255.255.255.128
 Secondary IP address: [Off]

Administrative Access

IPv4: ☒ HTTPS ☒ PING ☐ FMG-Access
☒ SSH ☐ SNMP ☐ FTM
☐ RADIUS Accounting ☐ Security Fabric Connection ☒ Speed Test
☐ SCIM

Receive LLDP: Use VDOM Setting Enable Disable
 Transmit LLDP: Use VDOM Setting Enable Disable

DHCP Server

DHCP status: Enabled Disabled
 Address range: 14.2.10.10-14.2.10.126

FortiGate: FGVMEVIAJSDQS84
 Status: Up
 MAC address: 50ac:18:00:0b:01

Additional Information
[API Preview](#)
[References](#)
[Edit in CLI](#)
[Online Guides](#)
[Relevant Documentation](#)
[Video Tutorials](#)
[Fortinet Community](#)
[Join the Discussion](#)

Configuración DHCP en interfaz LAN-USERS

Edit Interface

DHCP Server

DHCP status: Enabled Disabled
 Address range: 14.2.10.10-14.2.10.126
 Netmask: 255.255.255.128
 Default gateway: Same as Interface IP Specify
 DNS server: Same as System DNS Same as Interface IP Specify
 DNS server 1: 1.1.1.1
 DNS server 2: 14.2.10.1
 DNS server 3: 8.8.8.8
 Lease time: 604800 second(s)

FortiGate: FGVMEVIAJSDQS84
 Status: Up
 MAC address: 50ac:18:00:0b:01

Additional Information
[API Preview](#)
[References](#)
[Edit in CLI](#)
[Online Guides](#)
[Relevant Documentation](#)
[Video Tutorials](#)

Servidores DNS configurados en el DHCP

3.3 Validación desde el cliente

El cliente (VPC) recibió la IP 14.2.10.11/25 con gateway 14.2.10.1 de forma dinámica mediante DHCP.

```
VPC> ip dhcp
DDORA IP 14.2.10.11/25 GW 14.2.10.1
VPC>
```

Cliente recibe IP dinámica por DHCP

Se validó adicionalmente la salida a Internet con un ping exitoso a 1.1.1.1 desde el cliente.

```
VPC> ping 1.1.1.1

34 bytes from 1.1.1.1 icmp_seq=1 ttl=55 time=46.859 ms
34 bytes from 1.1.1.1 icmp_seq=2 ttl=55 time=46.663 ms
34 bytes from 1.1.1.1 icmp_seq=3 ttl=55 time=46.225 ms
34 bytes from 1.1.1.1 icmp_seq=4 ttl=55 time=45.125 ms
34 bytes from 1.1.1.1 icmp_seq=5 ttl=55 time=47.291 ms

VPC> █
```

Ping exitoso a 1.1.1.1 desde el cliente

De igual forma, se validó la conectividad a Internet desde el servidor web (14.2.20.10/28), confirmando ping exitoso a 1.1.1.1 y direccionamiento IP correcto.

```
root@WEB server:~# ping 1.1.1.1
PING 1.1.1.1 (1.1.1.1) 56(84) bytes of data.
64 bytes from 1.1.1.1: icmp_seq=1 ttl=55 time=45.9 ms
64 bytes from 1.1.1.1: icmp_seq=2 ttl=55 time=44.7 ms
64 bytes from 1.1.1.1: icmp_seq=3 ttl=55 time=45.0 ms
64 bytes from 1.1.1.1: icmp_seq=4 ttl=55 time=44.5 ms
64 bytes from 1.1.1.1: icmp_seq=5 ttl=55 time=47.1 ms
64 bytes from 1.1.1.1: icmp_seq=6 ttl=55 time=44.3 ms
64 bytes from 1.1.1.1: icmp_seq=7 ttl=55 time=45.3 ms
64 bytes from 1.1.1.1: icmp_seq=8 ttl=55 time=45.0 ms
64 bytes from 1.1.1.1: icmp_seq=9 ttl=55 time=43.8 ms
64 bytes from 1.1.1.1: icmp_seq=10 ttl=55 time=44.5 ms
^C
--- 1.1.1.1 ping statistics ---
10 packets transmitted, 10 received, 0% packet loss, time 9010ms
rtt min/avg/max/mdev = 43.823/45.011/47.114/0.883 ms
root@WEB server:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
34: eth0@if35: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:0a:b1:00:02 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.177.0.2/16 brd 10.177.255.255 scope global eth0
        valid_lft forever preferred_lft forever
37: docker1_0@if36: <BROADCAST,MULTICAST> mtu 9000 qdisc noop state DOWN group default qlen 1000
    link/ether 50:00:00:01:00:00 brd ff:ff:ff:ff:ff:ff link-netnsid 0
39: eth1@if38: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 9000 qdisc noqueue state UP group default qlen 1000
    link/ether 50:00:00:01:00:01 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 14.2.20.10/28 scope global eth1
        valid_lft forever preferred_lft forever
41: eth2@if40: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 9000 qdisc noqueue state LOWERLAYERDOWN group default qlen 1000
    link/ether 50:00:00:01:00:02 brd ff:ff:ff:ff:ff:ff link-netnsid 0
43: eth3@if42: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 9000 qdisc noqueue state LOWERLAYERDOWN group default qlen 1000
    link/ether 50:00:00:01:00:03 brd ff:ff:ff:ff:ff:ff link-netnsid 0
root@WEB server:~# █
```

Servidor web con conectividad a Internet e IP 14.2.20.10/28

4. Enrutamiento y NAT

4.1 Ruta por defecto

Destino	Gateway	Interfaz	Estado
0.0.0.0/0	10.0.0.1	port1	Enabled

Destination	Gateway IP	Interface	Status	Comments
0.0.0.0/0	10.0.0.1	port1	Enabled	

Ruta por defecto configurada

4.2 NAT

El NAT está habilitado en las políticas de salida hacia Internet (LAN-SERVERS → port1 y LAN-USERS → port1), permitiendo que el tráfico saliente sea traducido a la IP de la interfaz WAN. El NAT se encuentra deshabilitado en la política interna LAN-USERS → LAN-SERVERS, dado que es tráfico entre redes internas y no requiere traducción.

5. Políticas de Firewall

Política	Origen → Destino	Servicio	Acción	NAT	Perfiles de seguridad
NAT (2)	LAN-SERVERS → port1	ALL	ACCEPT	Enabled	WEB: Block-ITLA, SSL: deep-inspection
LAN-USERS (3)	LAN-USERS → LAN-SERVERS	HTTP	ACCEPT	Disabled	SSL: certificate-inspection, IPS: Scanner-Block, WAF: WAF-ServidorWEB
NAT (2)	LAN-USERS → port1	ALL	ACCEPT	Enabled	APP: APP-SOCIAL-BLOCK, WEB: Block-ITLA, SSL: deep-inspection
Implicit Deny	all → all	ALL	DENY	—	—

Esta configuración garantiza que:

- Los usuarios solo pueden acceder a los servidores internos vía HTTP (puerto 80); cualquier otro protocolo o puerto es bloqueado por la política implícita final.
- El tráfico de salida a redes sociales se controla en la política de Internet (LAN-USERS → port1), donde corresponde, ya que ese tráfico va hacia servicios externos y no hacia la LAN de servidores interna.
- El IPS y el WAF protegen específicamente el tráfico dirigido hacia el servidor web interno.

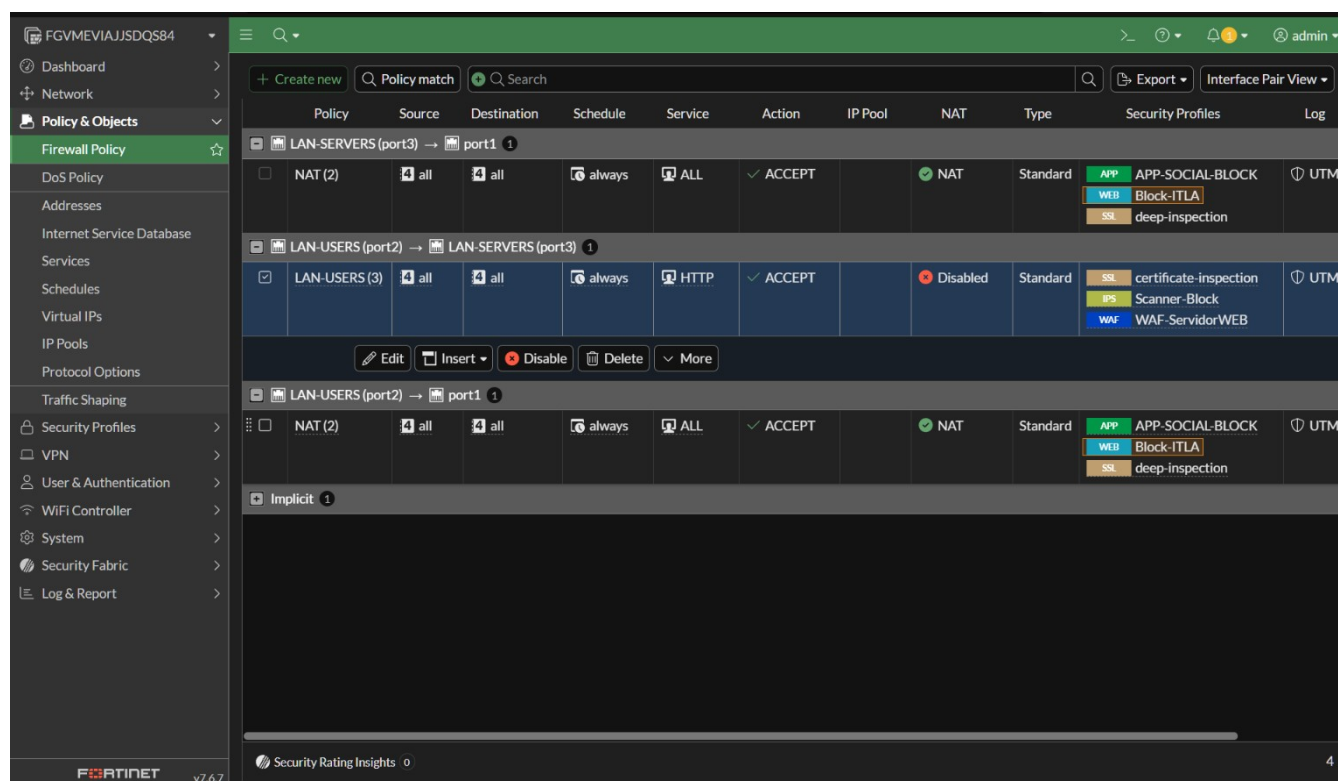


Tabla completa y final de políticas de firewall con todos los perfiles aplicados

5.1 Prueba funcional: solo HTTP permitido entre LANs

Desde el cliente en la LAN de usuarios se realizaron las siguientes pruebas: ping a 1.1.1.1 (Internet, exitoso), ping a 14.2.20.10 (servidor web, bloqueado por timeout) y ping a 14.2.20.1 (gateway de servidores, bloqueado por timeout). Esto confirma que el protocolo ICMP está correctamente bloqueado entre LANs por la política implícita, mientras que el tráfico HTTP sí es aceptado según lo verificado en el navegador del cliente.

```
VPC> ping 1.1.1.1
84 bytes from 1.1.1.1 icmp_seq=1 ttl=55 time=46.859 ms
84 bytes from 1.1.1.1 icmp_seq=2 ttl=55 time=46.663 ms
84 bytes from 1.1.1.1 icmp_seq=3 ttl=55 time=46.225 ms
84 bytes from 1.1.1.1 icmp_seq=4 ttl=55 time=45.125 ms
84 bytes from 1.1.1.1 icmp_seq=5 ttl=55 time=47.291 ms

VPC> ping 14.2.20.10
14.2.20.10 icmp_seq=1 timeout
14.2.20.10 icmp_seq=2 timeout
14.2.20.10 icmp_seq=3 timeout
14.2.20.10 icmp_seq=4 timeout
14.2.20.10 icmp_seq=5 timeout

VPC> ping 14.2.20.1
14.2.20.1 icmp_seq=1 timeout
14.2.20.1 icmp_seq=2 timeout
14.2.20.1 icmp_seq=3 timeout
14.2.20.1 icmp_seq=4 timeout
14.2.20.1 icmp_seq=5 timeout

VPC>
```

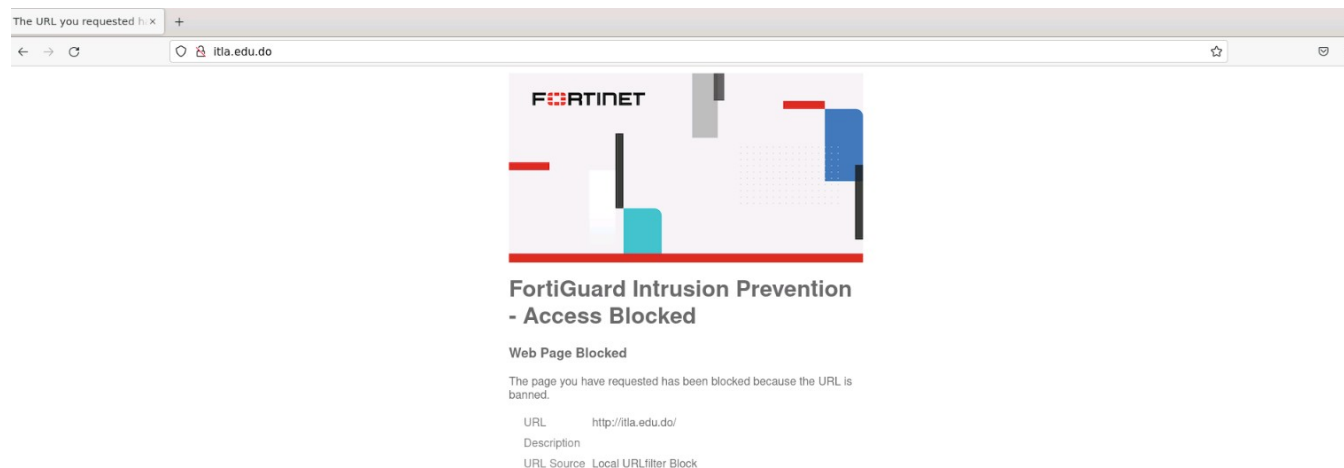
Ping bloqueado hacia servidor y gateway; solo Internet responde

6. Perfiles de seguridad configurados

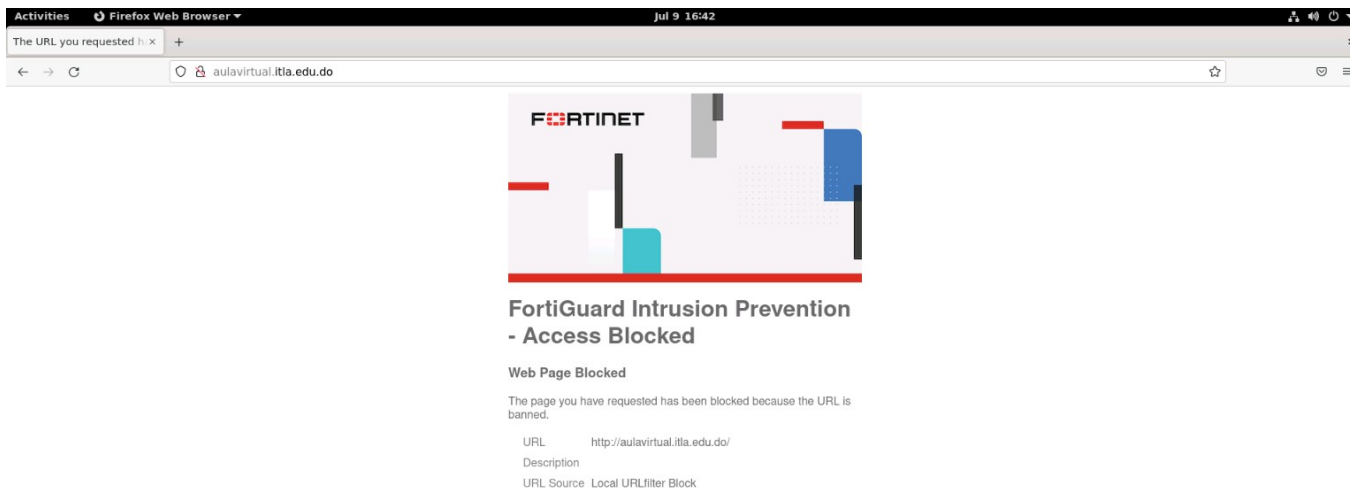
6.1 Web Filter — Bloqueo de itla.edu.do

Perfil Block-ITLA, con Static URL Filter y las siguientes reglas tipo Wildcard: itla.edu.do y *.itla.edu.do, ambas con acción Block. Esta combinación cubre tanto el dominio raíz como todos sus subdominios.

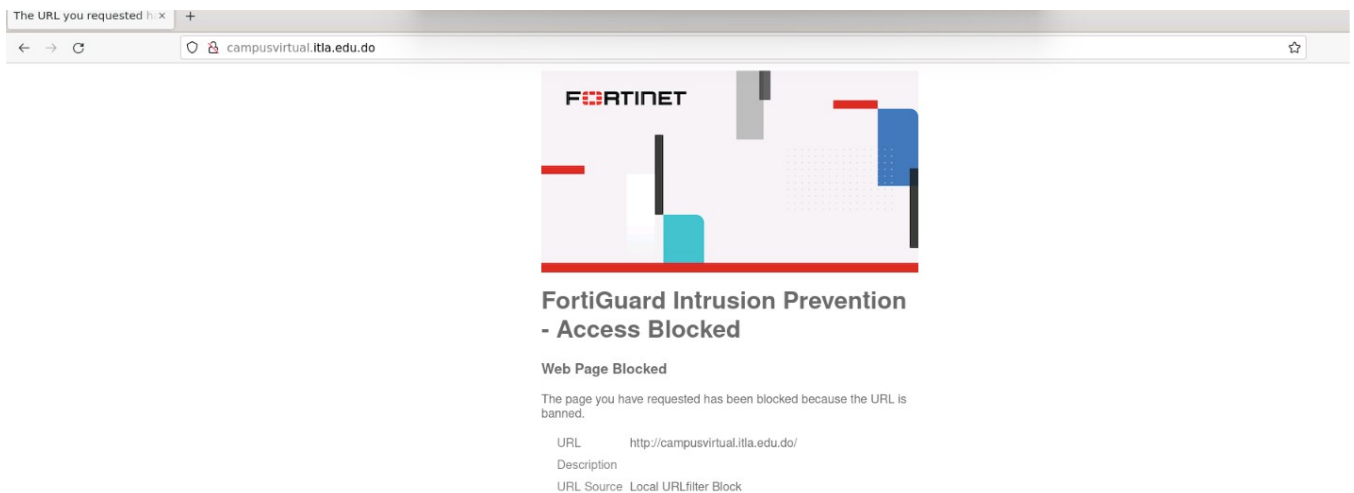
Se realizaron pruebas exitosas de bloqueo contra tres URLs distintas del dominio, confirmando el correcto funcionamiento del wildcard:



Bloqueo confirmado: itla.edu.do (dominio raíz)



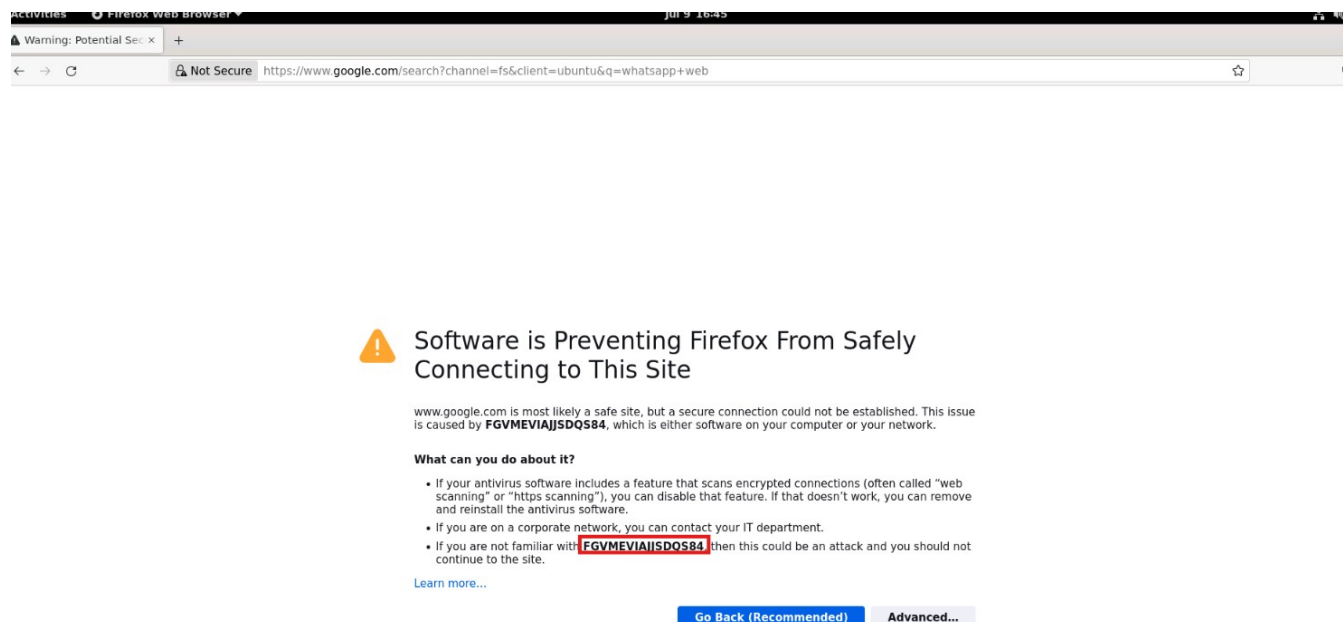
Bloqueo confirmado: aulavirtual.itla.edu.do



Bloqueo confirmado: campusvirtual.itla.edu.do

Nota técnica — SSL Deep Inspection

Para que Web Filter, Application Control y WAF puedan inspeccionar tráfico HTTPS, se configuró el perfil SSL/SSH Inspection en modo Deep Inspection en las políticas de salida a Internet. Esto se evidencia en la advertencia de certificado que el navegador del cliente presenta al detectar el certificado sustituto emitido por FortiGate (nombre del dispositivo FGVMEVIAJSDQS84) en lugar del certificado original del sitio visitado. Este comportamiento es esperado y necesario para la inspección de contenido cifrado; en un entorno de producción, el certificado CA de FortiGate se distribuiría a los clientes para evitar esta advertencia.



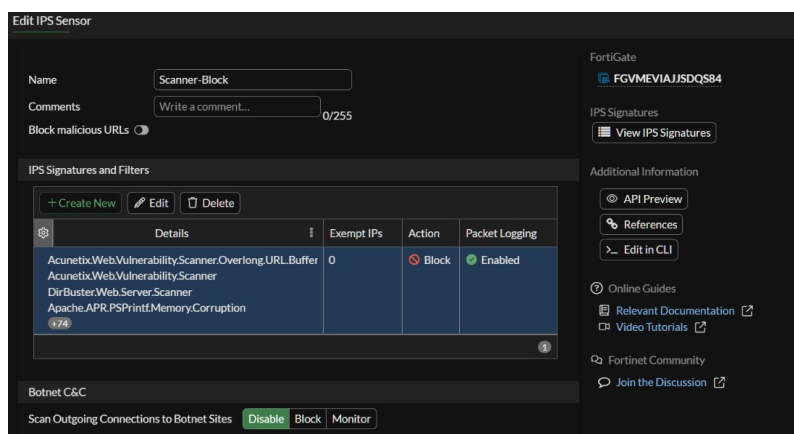
Advertencia de certificado, evidencia de SSL Deep Inspection activo

6.2 Application Control — Bloqueo de redes sociales y llamadas de WhatsApp

Perfil APP-SOCIAL-BLOCK aplicado en la política de salida a Internet (LAN-USERS → port1), con la categoría Social Media bloqueada y un override específico para la firma WhatsApp_VoIP.Call en modo Block. Esta configuración se verificó en vivo, confirmando el bloqueo del acceso a redes sociales y de las llamadas de voz/video de WhatsApp desde la LAN de usuarios.

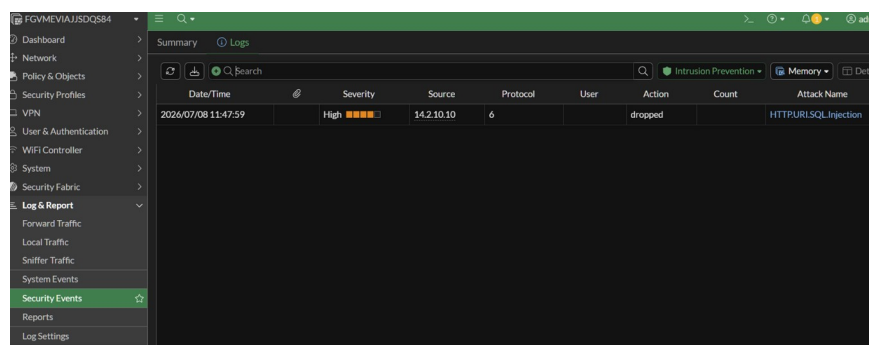
6.3 Intrusion Prevention — Detección de escáneres de red

Perfil Scanner-Block, configurado con más de 75 firmas relacionadas a escaneo y explotación web, incluyendo Acunetix.Web.Vulnerability.Scanner, Acunetix.Web.Vulnerability.Scanner.Overlong.URL.Buffer, DirBuster.Web.Server.Scanner y Apache.APR.PSprintf.Memory.Corruption, todas en acción Block con Packet Logging habilitado.



Perfil Scanner-Block con firmas de detección de escáneres

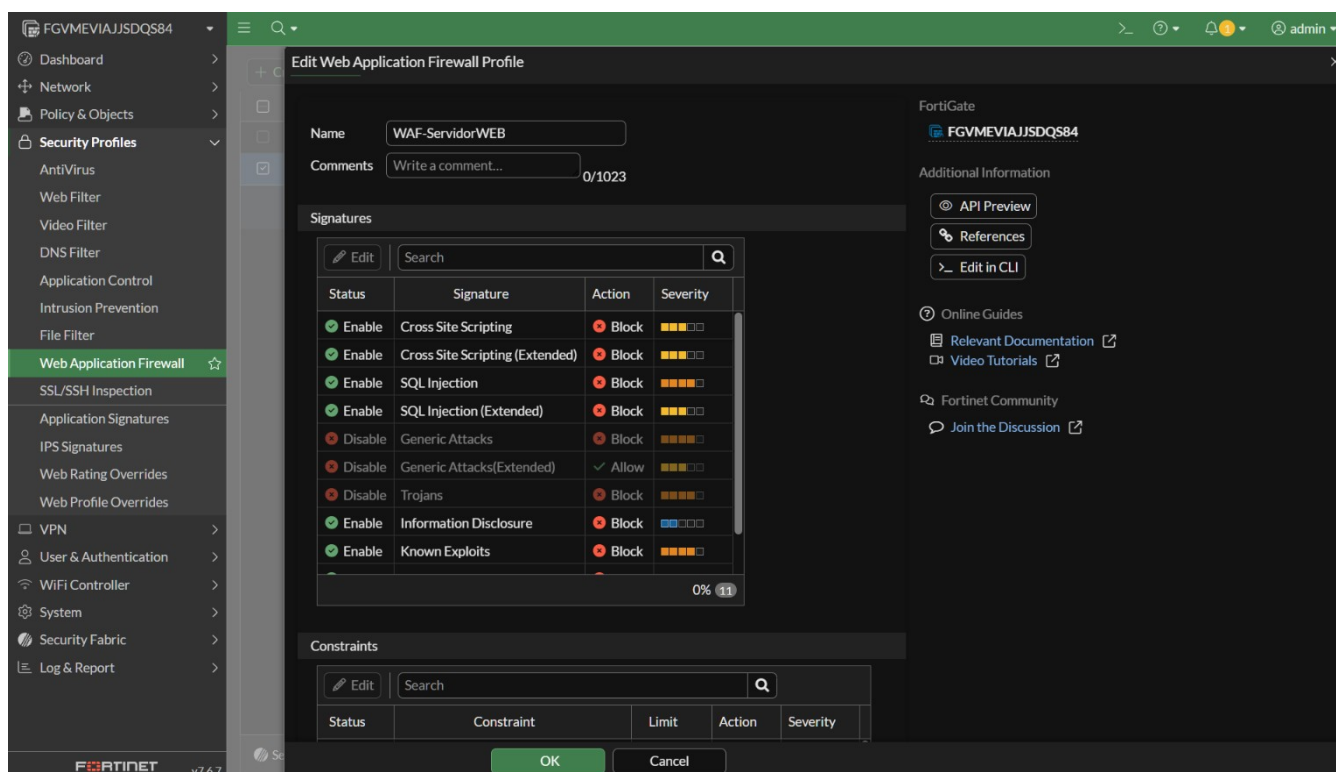
Este perfil está aplicado en la política LAN-USERS → LAN-SERVERS. Se confirmó su funcionamiento real mediante el log de Security Events, donde se registró la detección y bloqueo (dropped) de un intento de ataque HTTP.URI.SQL.Injection con severidad alta, originado desde el cliente 14.2.10.10 hacia el servidor web.



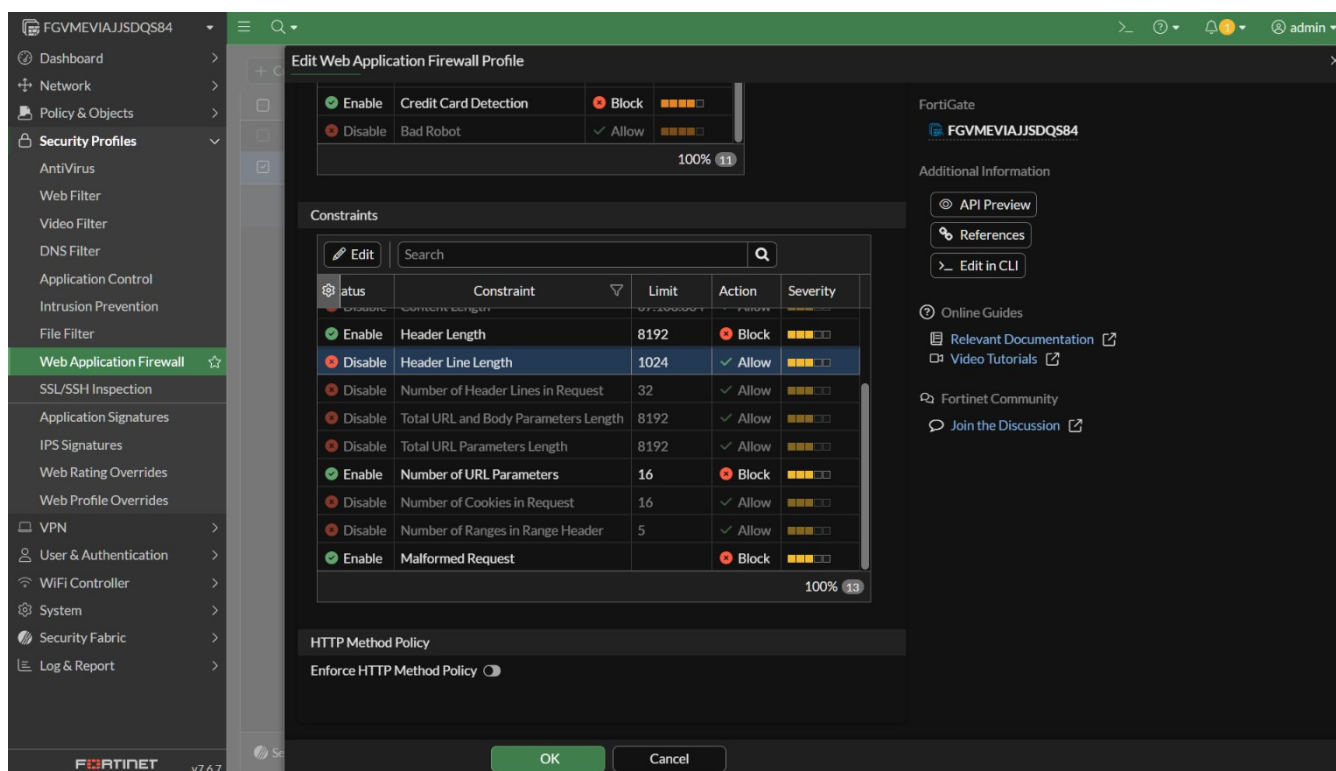
Log de Security Events: ataque SQL Injection detectado y bloqueado por el IPS

6.4 Web Application Firewall (WAF)

Perfil WAF-ServidorWEB, configurado con las siguientes firmas en modo Block: Cross Site Scripting, Cross Site Scripting (Extended), SQL Injection, SQL Injection (Extended), Known Exploits, Information Disclosure y Credit Card Detection. Adicionalmente se configuraron las siguientes restricciones (Constraints) en modo Block: Header Length, Number of URL Parameters y Malformed Request.



Perfil WAF-ServidorWEB — Firmas configuradas



Perfil WAF-ServidorWEB — Restricciones (Constraints) configuradas

Este perfil está aplicado en la política LAN-USERS → LAN-SERVERS, protegiendo directamente al servidor web de ataques a nivel de aplicación. Su funcionamiento fue verificado en vivo mediante pruebas con payloads de SQL Injection y Cross Site Scripting, confirmando el bloqueo correcto de dichas solicitudes antes de llegar al servidor.

7. Resumen de cumplimiento

#	Requisito	Estado	Observación
1	Configuración por GUI	Cumplido	Toda la configuración realizada vía GUI
2	Acceso a Internet	Cumplido	Ping exitoso a 1.1.1.1 desde cliente y servidor
3	LAN de usuarios /25	Cumplido	14.2.10.0/25
4	LAN de servidores /28	Cumplido	14.2.20.0/28
5	IP en interfaces	Cumplido	port1, port2, port3 configuradas
6	DHCP en LAN usuarios	Cumplido	Rango 14.2.10.10-126, validado en cliente
7	Ruta por defecto	Cumplido	0.0.0.0/0 vía 10.0.0.1
8	NAT	Cumplido	Habilitado en salida a Internet
9	Solo HTTP usuarios→servidores	Cumplido	Ping bloqueado + HTTP funcional, verificado
10	Bloqueo de redes sociales	Cumplido	Verificado en vivo con Application Control
11	Bloqueo llamadas WhatsApp	Cumplido	Override WhatsApp_VoIP.Call, verificado en vivo
12	Bloqueo itla.edu.do	Cumplido	3 pruebas de bloqueo confirmadas (dominio + 2 subdominios)
13	IPS + WAF	Cumplido	IPS: bloqueo real de SQL Injection registrado en logs. WAF: verificado en vivo con payloads SQLi/XSS

8. Anexos

Listado de capturas de pantalla incluidas en este documento:

- 01_interfaces.png — Network → Interfaces (tabla completa)
- 02_static_routes.png — Network → Static Routes
- 03_dhcp_config.png — Edit Interface → DHCP Server (LAN-USERS)
- 04_dhcp_dns.png — DHCP Server, configuración de DNS
- 05_cliente_dhcp.png — Cliente recibiendo IP dinámica por DHCP
- 06_cliente_ping.png — Ping exitoso a 1.1.1.1 desde el cliente
- 07_server_ping_ip.png — Servidor web con conectividad e IP asignada
- 08_http_only_proof.png — Prueba de política HTTP-only (ping bloqueado)
- 09_firewall_policy_final.png — Tabla completa y final de políticas de firewall
- 10_block_aulavirtual.png — Bloqueo de aulavirtual.itla.edu.do
- 11_block_campusvirtual.png — Bloqueo de campusvirtual.itla.edu.do

- 12_block_itla_root.png — Bloqueo de itla.edu.do
- 13_ssl_deepinspection_warning.png — Evidencia de SSL Deep Inspection
- 14_waf_signatures.png — Perfil WAF: firmas configuradas
- 15_waf_constraints.png — Perfil WAF: restricciones configuradas
- 16_scanner_block_final.png — Perfil IPS Scanner-Block con firmas
- 17_ips_log_sqli.png — Log de bloqueo real de ataque SQL Injection por el IPS